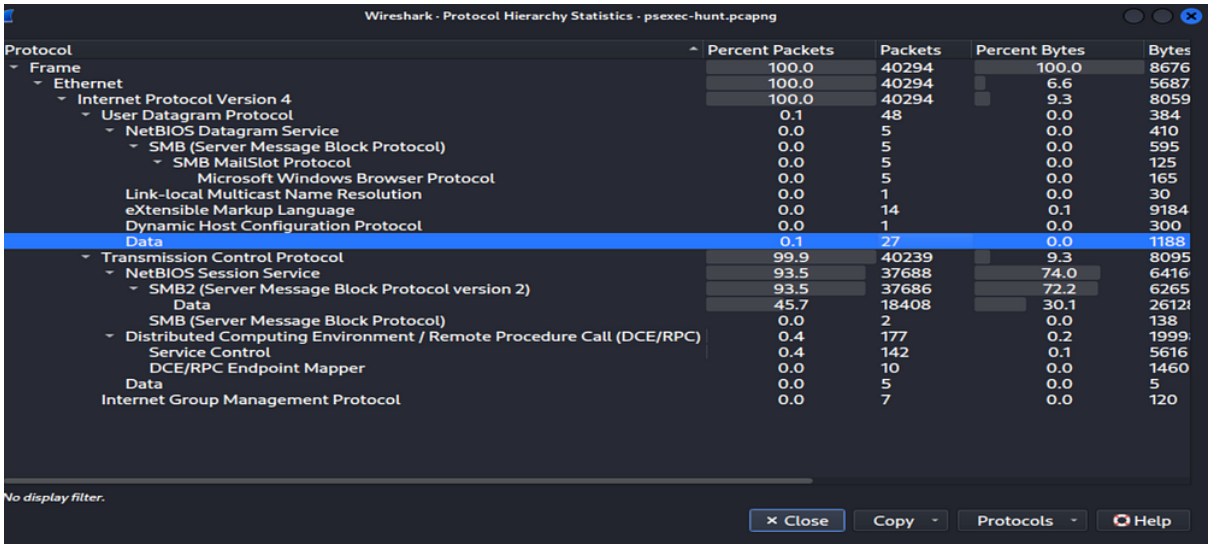
PsExec Hunt Lab

Penulis: Firman Maulana

Pada lab kali ini kita akan belajar menanalisa log dari file pcap, dimana pada skenarionya dalah berikut:

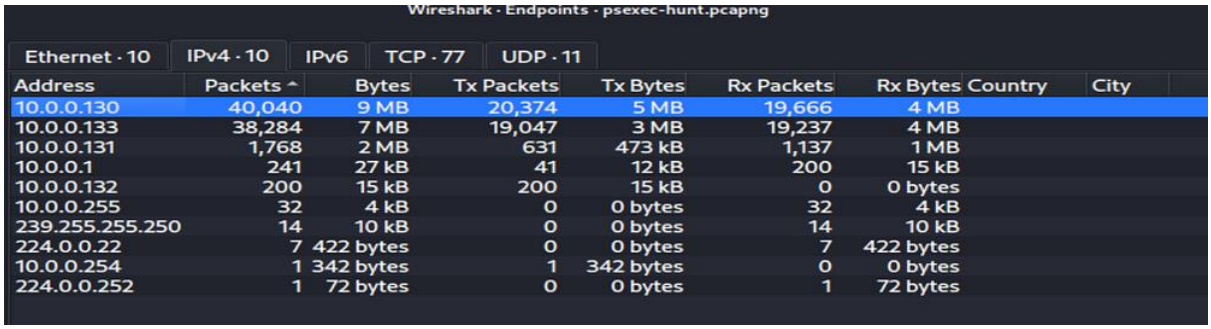
Peringatan dari Sistem Deteksi Intrusi (IDS) menandai aktivitas gerakan lateral yang mencurigakan yang melibatkan PsExec. Ini menunjukkan potensi akses dan pergerakan yang tidak sah di seluruh jaringan. Sebagai analis SOC, tugas Anda adalah menyelidiki file PCAP yang disediakan untuk melacak aktivitas penyerang. Identifikasi titik masuk mereka, mesin yang ditargetkan, tingkat pelanggaran, dan indikator penting apa pun yang mengungkapkan taktik dan tujuan mereka dalam lingkungan yang disusupi.

untuk labnya silahkan klik *disini* yaa jika ingin praktek juga.



Protocol	Percent Packets	Packets	Percent Bytes	Bytes
Frame	100.0	40294	100.0	8676
Ethernet	100.0	40294	6.6	5687
Internet Protocol Version 4	100.0	40294	9.3	8059
User Datagram Protocol	0.1	48	0.0	384
NetBIOS Datagram Service	0.0	5	0.0	410
SMB (Server Message Block Protocol)	0.0	5	0.0	595
SMB MailSlot Protocol	0.0	5	0.0	125
Microsoft Windows Browser Protocol	0.0	5	0.0	165
Link-local Multicast Name Resolution	0.0	1	0.0	30
eXtensible Markup Language	0.0	14	0.1	9184
Dynamic Host Configuration Protocol	0.0	1	0.0	300
Data	0.1	27	0.0	1188
Transmission Control Protocol	99.9	40239	9.3	8095
NetBIOS Session Service	93.5	37688	74.0	6416
SMB2 (Server Message Block Protocol version 2)	93.5	37686	72.2	6265
Data	45.7	18408	30.1	26128
SMB (Server Message Block Protocol)	0.0	2	0.0	138
Distributed Computing Environment / Remote Procedure Call (DCE/RPC)	0.4	177	0.2	1999
Service Control	0.4	142	0.1	5616
DCE/RPC Endpoint Mapper	0.0	10	0.0	1460
Data	0.0	5	0.0	5
Internet Group Management Protocol	0.0	7	0.0	120

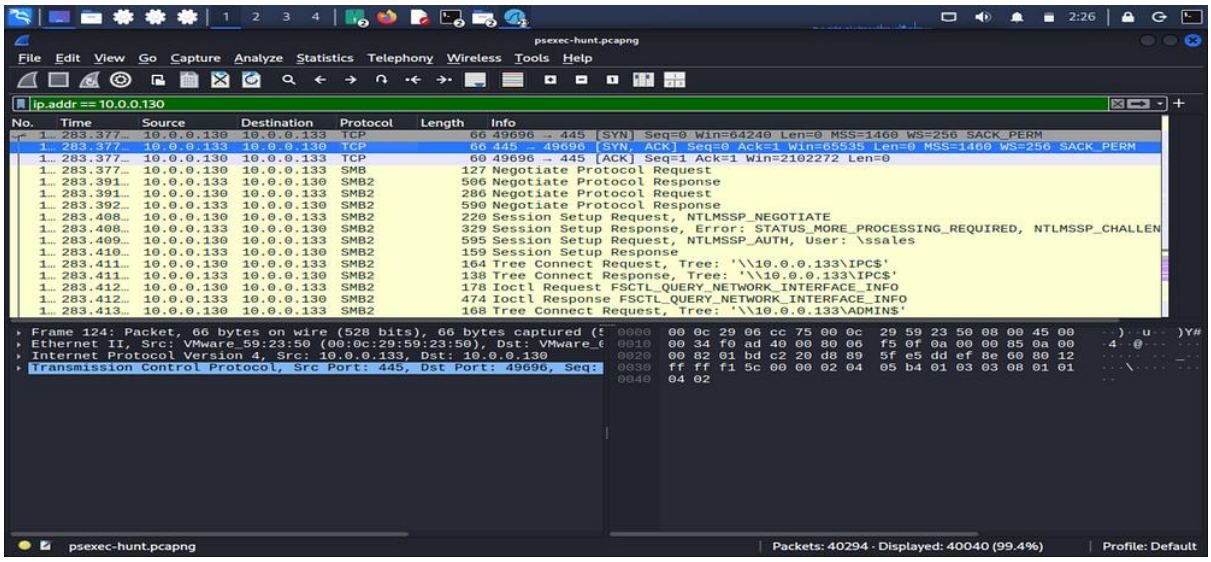
Saat saya gunakan menu Protokol Huerarchy terdapat packets yang trafiknya tinggi pada data dan service control, hal ini menjadi mencurigakan.



Address	Packets	Bytes	Tx Packets	Tx Bytes	Rx Packets	Rx Bytes	Country	City
10.0.0.130	40,040	9 MB	20,374	5 MB	19,666	4 MB		
10.0.0.133	38,284	7 MB	19,047	3 MB	19,237	4 MB		
10.0.0.131	1,768	2 MB	631	473 kB	1,137	1 MB		
10.0.0.1	241	27 kB	41	12 kB	200	15 kB		
10.0.0.132	200	15 kB	200	15 kB	0	0 bytes		
10.0.0.255	32	4 kB	0	0 bytes	32	4 kB		
239.255.255.250	14	10 kB	0	0 bytes	14	10 kB		
224.0.0.22	7	422 bytes	0	0 bytes	7	422 bytes		
10.0.0.254	1	342 bytes	1	342 bytes	0	0 bytes		
224.0.0.252	1	72 bytes	0	0 bytes	1	72 bytes		

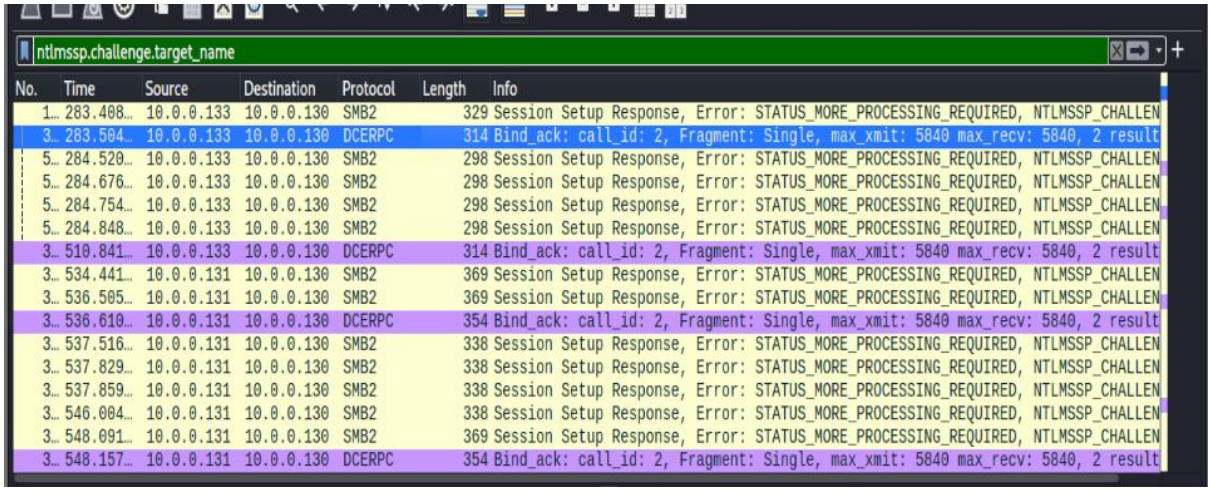
Setelah itu saya cek Pada endpoint dan terdapat trafik yang cenderung dominan tinggi pada ip 10.0.0.130 dan 10.0.0.133

1. Untuk melacak aktivitas penyerang secara efektif di dalam jaringan kita, dapatkah Anda mengidentifikasi alamat IP dari mesin yang digunakan penyerang untuk pertama kali mengakses jaringan?

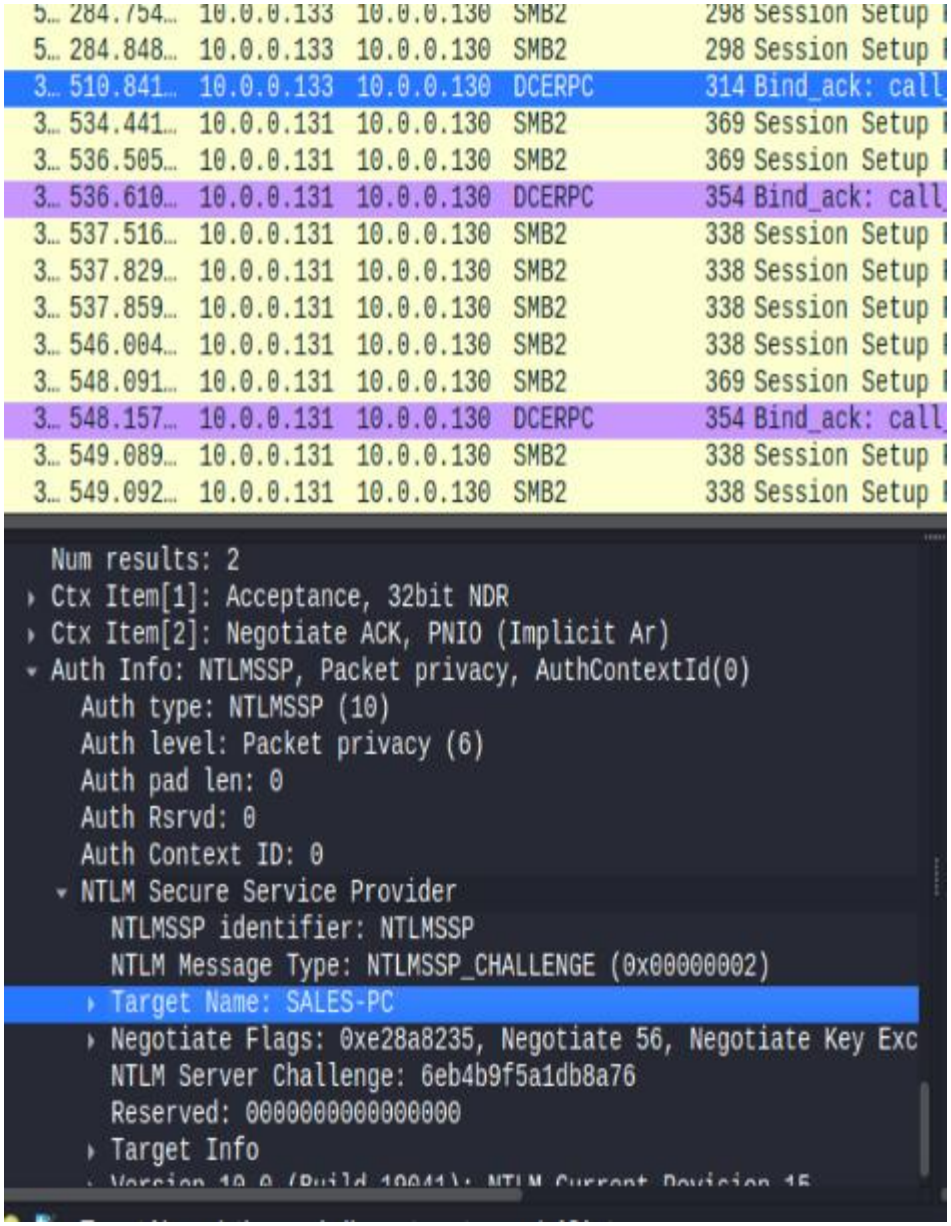


Setelah memfilter pada ip tersebut dan ternyata ip tersebut saling komunikasi, kemungkinan ip penyerang itu adalah **10.0.0.130**, karena ip tersebut banyak mengirim seperti query ke ip 10.0.0.133.

2. Untuk memahami sepenuhnya sejauh mana pelanggaran tersebut, dapatkah Anda menentukan nama host mesin yang pertama kali dituju oleh penyerang?

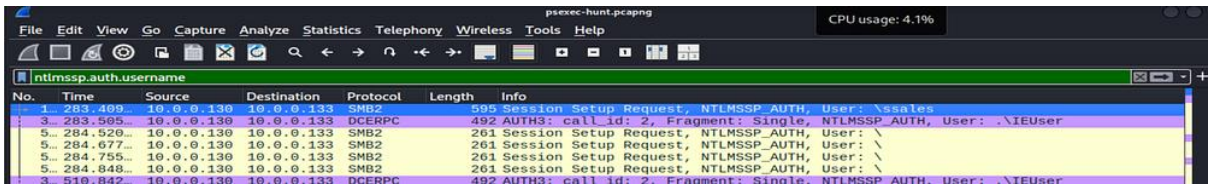


Kemudian saya filter dengan **ntlmssp.challenge.target_name**, dan mendapatkan beberapa log yang mengandung target name.



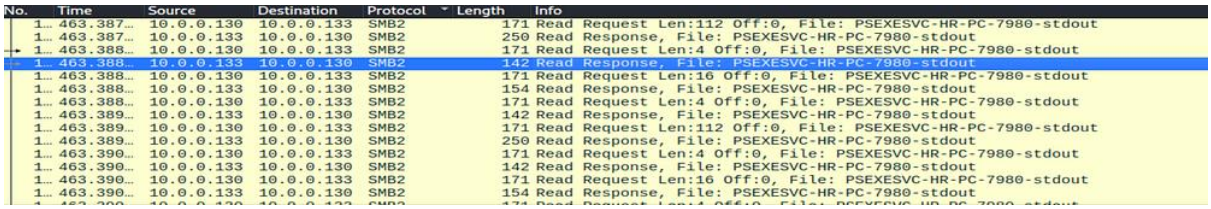
Setelah itu saya buka isi lognya terdapat nama target yaitu **SALES-PC**

3. Mengetahui nama pengguna akun yang digunakan penyerang untuk otentikasi akan memberi kita wawasan tentang sejauh mana pelanggaran tersebut terjadi. Apa nama pengguna yang digunakan penyerang untuk otentikasi?



Untuk menjawab pertanyaan selanjutnya saya menggunakan filter **ntlmssp.auth.username**, dan setelah saya filter terdapat user yaitu **ssales** pada baris pertama.

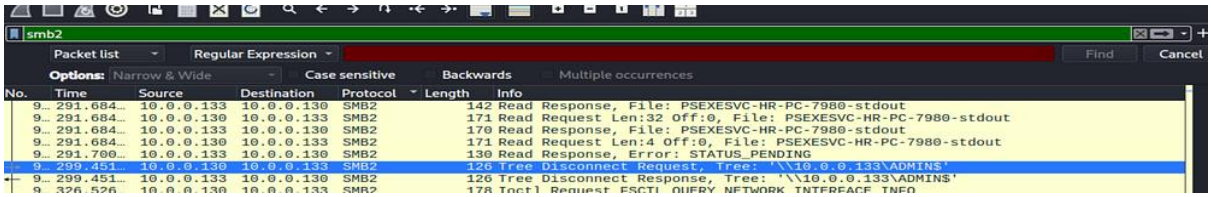
4. Setelah mengetahui bagaimana penyerang bergerak di dalam jaringan kita, kita perlu mengetahui apa yang mereka lakukan pada mesin target. Apa nama executable layanan yang disiapkan penyerang pada target?



No.	Time	Source	Destination	Protocol	Length	Info
1…	463.387…	10.0.0.130	10.0.0.133	SMB2	171	Read Request Len:112 Off:0, File: PSEXESVC-HR-PC-7980-stdout
1…	463.387…	10.0.0.133	10.0.0.130	SMB2	250	Read Response, File: PSEXESVC-HR-PC-7980-stdout
1…	463.388…	10.0.0.130	10.0.0.133	SMB2	171	Read Request Len:4 Off:0, File: PSEXESVC-HR-PC-7980-stdout
1…	463.388…	10.0.0.133	10.0.0.130	SMB2	142	Read Response, File: PSEXESVC-HR-PC-7980-stdout
1…	463.388…	10.0.0.130	10.0.0.133	SMB2	171	Read Request Len:16 Off:0, File: PSEXESVC-HR-PC-7980-stdout
1…	463.388…	10.0.0.133	10.0.0.130	SMB2	154	Read Response, File: PSEXESVC-HR-PC-7980-stdout
1…	463.388…	10.0.0.130	10.0.0.133	SMB2	171	Read Request Len:4 Off:0, File: PSEXESVC-HR-PC-7980-stdout
1…	463.389…	10.0.0.133	10.0.0.130	SMB2	142	Read Response, File: PSEXESVC-HR-PC-7980-stdout
1…	463.389…	10.0.0.130	10.0.0.133	SMB2	171	Read Request Len:112 Off:0, File: PSEXESVC-HR-PC-7980-stdout
1…	463.389…	10.0.0.133	10.0.0.130	SMB2	250	Read Response, File: PSEXESVC-HR-PC-7980-stdout
1…	463.390…	10.0.0.130	10.0.0.133	SMB2	171	Read Request Len:4 Off:0, File: PSEXESVC-HR-PC-7980-stdout
1…	463.390…	10.0.0.133	10.0.0.130	SMB2	142	Read Response, File: PSEXESVC-HR-PC-7980-stdout
1…	463.390…	10.0.0.130	10.0.0.133	SMB2	171	Read Request Len:16 Off:0, File: PSEXESVC-HR-PC-7980-stdout
1…	463.390…	10.0.0.133	10.0.0.130	SMB2	154	Read Response, File: PSEXESVC-HR-PC-7980-stdout

Untuk menjawab nomor selanjutnya yaitu dengan filter **SMB2**, kareena saya mencurigai jika penyerang melakukan serangan melalui port SMB karena ip penyerang tersebut menunjukan kalau melakukan aktifitas di port itu, dan hasil filter saya mendapatkan nama executable **psexesvc.**

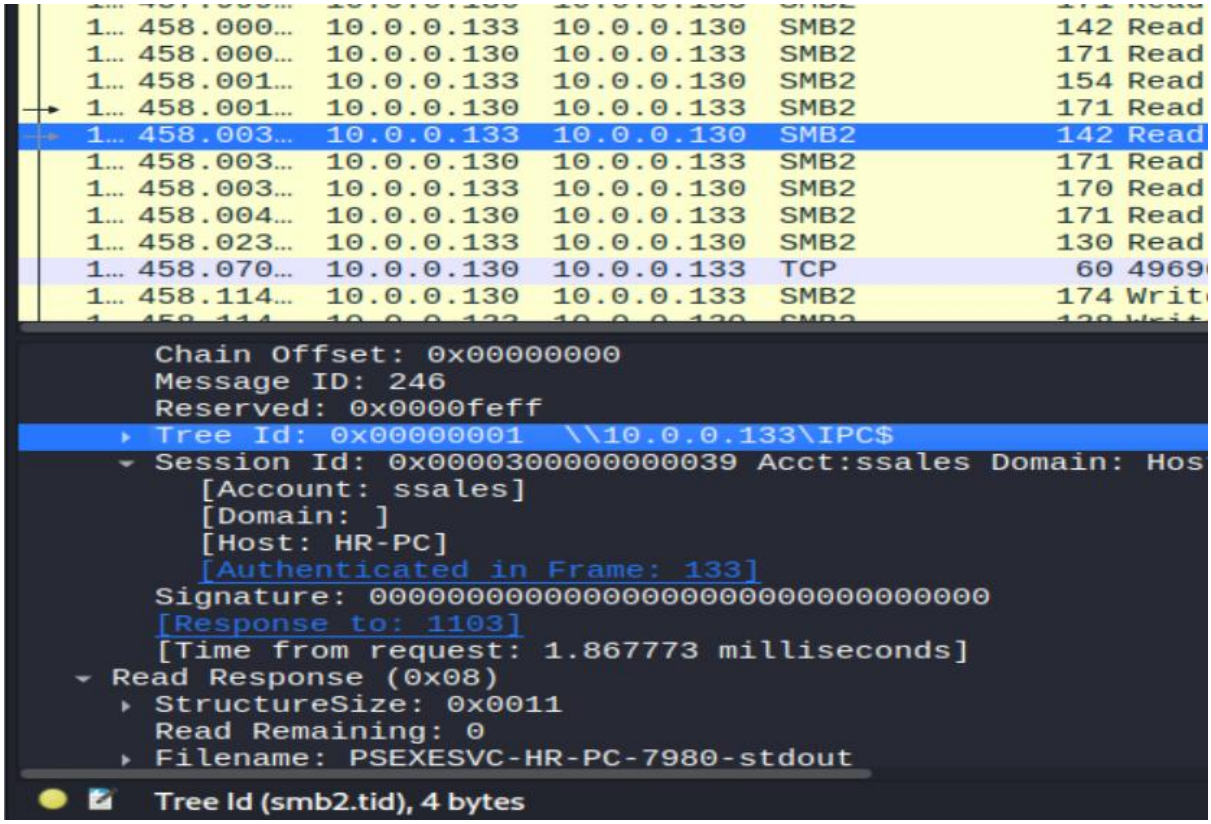
5. Kita perlu mengetahui bagaimana penyerang memasang layanan tersebut pada mesin yang disusupi untuk memahami taktik pergerakan lateral penyerang. Hal ini dapat membantu mengidentifikasi sistem lain yang terpengaruh. Jaringan berbagi mana yang digunakan oleh PsExec untuk memasang layanan tersebut pada mesin target?



No.	Time	Source	Destination	Protocol	Length	Info
9…	291.684…	10.0.0.133	10.0.0.130	SMB2	142	Read Response, File: PSEXESVC-HR-PC-7980-stdout
9…	291.684…	10.0.0.130	10.0.0.133	SMB2	171	Read Request Len:32 Off:0, File: PSEXESVC-HR-PC-7980-stdout
9…	291.684…	10.0.0.133	10.0.0.130	SMB2	170	Read Response, File: PSEXESVC-HR-PC-7980-stdout
9…	291.684…	10.0.0.130	10.0.0.133	SMB2	171	Read Request Len:4 Off:0, File: PSEXESVC-HR-PC-7980-stdout
9…	291.700…	10.0.0.133	10.0.0.130	SMB2	130	Read Response, Error: STATUS_PENDING
9…	299.451…	10.0.0.130	10.0.0.133	SMB2	126	Tree Disconnect Request, Tree: '\\10.0.0.133\ADMIN$'
9…	299.451…	10.0.0.133	10.0.0.130	SMB2	126	Tree Disconnect Response, Tree: '\\10.0.0.133\ADMIN$'
9…	326.526…	10.0.0.130	10.0.0.133	SMB2	178	Ioctl Request FSCTL_QUERY_NETWORK_INTERFACE_INFO

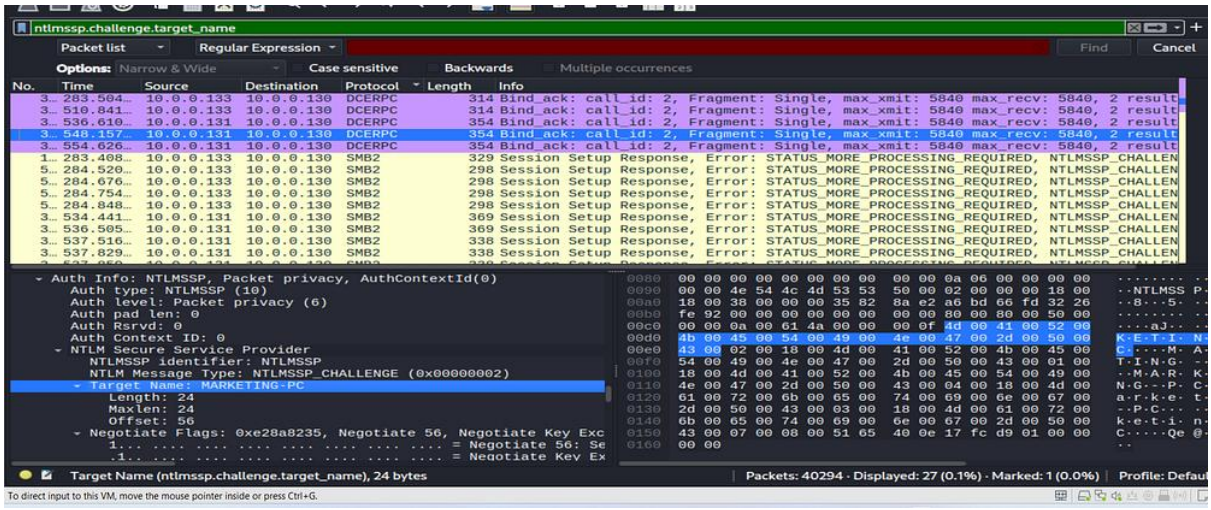
Setelah saya analisa dan saya filter dengan smb2 dan di beberapa log terdapat **'\\10.0.0.133\ADMIN$'**, dan yang mebjadi jawaban nomor ini adalah **ADMIN$**

6. Kita harus mengidentifikasi share jaringan yang digunakan untuk berkomunikasi antara kedua mesin tersebut. Share jaringan mana yang digunakan PsExec untuk berkomunikasi?



Seperti sebelumnya saya menggunakan filer smb2 dan setelah beberapa lama analisis saya menemukan **'\\10.0.0.133\IPC$',** dan ini menandakan jika yang digunakan untuk komunikasi Adalah **IPC$.**

7. Sekarang setelah kita memiliki gambaran yang lebih jelas tentang aktivitas penyerang pada mesin yang disusupi, penting untuk mengidentifikasi pergerakan lateral lebih lanjut. Apa nama host dari mesin kedua yang ditargetkan penyerang untuk melakukan pivot di dalam jaringan kita?



Untuk mencari nama host tersebut saya menggunkan filter **ntlmssp.chsllenge.target_name**, setelah saya mencoba membuka beberapa log, terdapat nama target yaitu **MARKETING-PC.**

Kesimpulan

Pada lab kali ini menunjukan jika sebuah filter sangat penting untuk menemukan sebuah hal yang tersimpan dibanyaknya log yang ada, hal ini untuk mempermudah menganalisis sebuah jaringan dan mencari rahu anomali yang melakukan serangan untuk nantinya dijadikan bukti atau alat hukum.